

AAA -- Accounting -- Guided Notes ANSWER KEY

Unit tp-6.7 | CompTIA Network+ N10-009 Obj. FC0-U71 6.1 | N10-008 FC0-U71 6.1

For instructor use / distribute after students complete the notes.

Question 1

Accounting (the third A in AAA) is the process of _____ user activity on a system. It creates a record of who _____ in, what they _____, and when they logged _____. This record is called an _____ log or audit trail.

Answer: Tracking; logged; accessed/did; out; audit.

Question 2

Audit logs provide _____ -- the ability to trace activity back to a specific user. This supports _____ investigations after a breach, regulatory _____ (HIPAA, PCI-DSS require logs), and detection of _____ anomalies like a user accessing files outside business hours.

Answer: Accountability; forensic; compliance; suspicious.

Question 3

A SIEM (Security Information and Event Management) system _____ logs from multiple devices and applications into a central _____ for analysis and alerting. It correlates events across sources to detect _____ that no single log would reveal. Examples include Splunk, Microsoft Sentinel, and IBM QRadar.

Answer: Aggregates (collects); platform (console); patterns (attacks).

Question 4

Logs should be _____ to a separate server or write-once storage because an attacker who compromises the host may _____ logs to cover their tracks. _____ logging requires that logs cannot be modified once written. Time _____ ensures all logs share a consistent clock using NTP so events from multiple systems can be correlated accurately.

Answer: Forwarded; delete (alter); Immutable; synchronization.

Question 5

Common events that should always be logged include: _____ successes and failures (who tried to log in), _____ changes (who changed what permissions), _____ access (who read or exported sensitive files), and _____ (creating, deleting, modifying accounts). Together these events form a security baseline for detecting insider threats.

Answer: Login; privilege; data; user management.

Question 6

Log _____ refers to how long logs are retained before deletion. HIPAA requires audit logs to be retained for _____ years. PCI-DSS requires _____ months. Too-short retention means logs may not be available during a forensic investigation. Organizations should define a _____ policy that

balances compliance, storage cost, and investigation needs.

Answer: Retention; 6; 12 (1 year); log retention.

Question 7

Non-repudiation means a user _____ deny having performed an action when logs prove they did.

Digital _____ provide non-repudiation for electronic documents and transactions. In accounting, it is the combination of _____ (proving who acted) and _____ (proving the action was recorded) that creates non-repudiation.

Answer: Cannot; signatures; authentication; logging.

Question 8 -- Real World Application

REAL WORLD: A hospital systems administrator is suspected of accessing patient records for celebrities without a clinical reason. The privacy officer wants to investigate, but the access logs are only retained for 30 days and the alleged access occurred 45 days ago. The logs are gone. Identify the compliance failure, which regulation was violated, and describe two logging practices that would have allowed the investigation to proceed.

Answer: Compliance failure: HIPAA requires covered entities to retain access audit logs for a minimum of 6 years (not 30 days). The hospital is in violation of HIPAA's audit control requirements (45 CFR 164.312(b)) and record retention requirements. This is not just a privacy program failure -- it carries regulatory penalty risk. Practice 1 -- HIPAA-compliant log retention policy: set the log retention period to 6 years minimum across all systems handling PHI. Storage is inexpensive -- 6 years of access logs for a mid-size hospital costs much less than a HIPAA violation fine (which can reach \$1.9 million per violation category). Practice 2 -- Automated log archival to immutable cold storage: configure the SIEM and EHR system to automatically archive access logs to write-once cloud storage (e.g., AWS S3 Glacier with object lock) after 30 days. The logs are no longer hot (fast), but they remain recoverable for investigation or audit for the full retention period.